

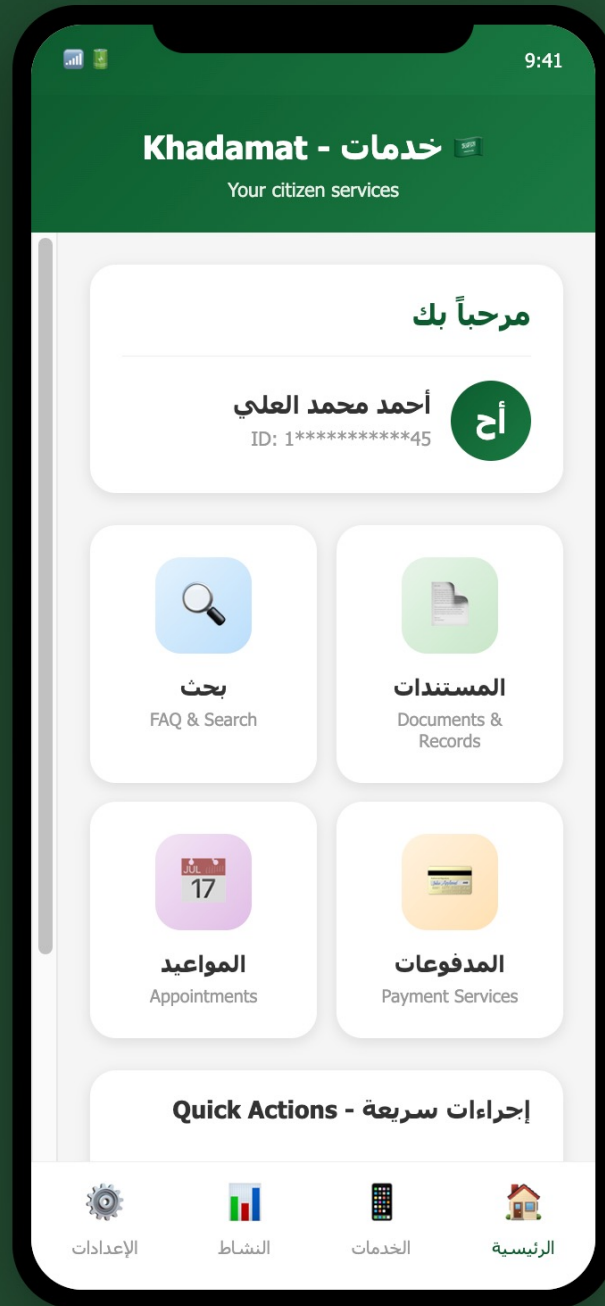


# Building secure Generative AI applications

Achraf Souk

Principal Solutions Architect

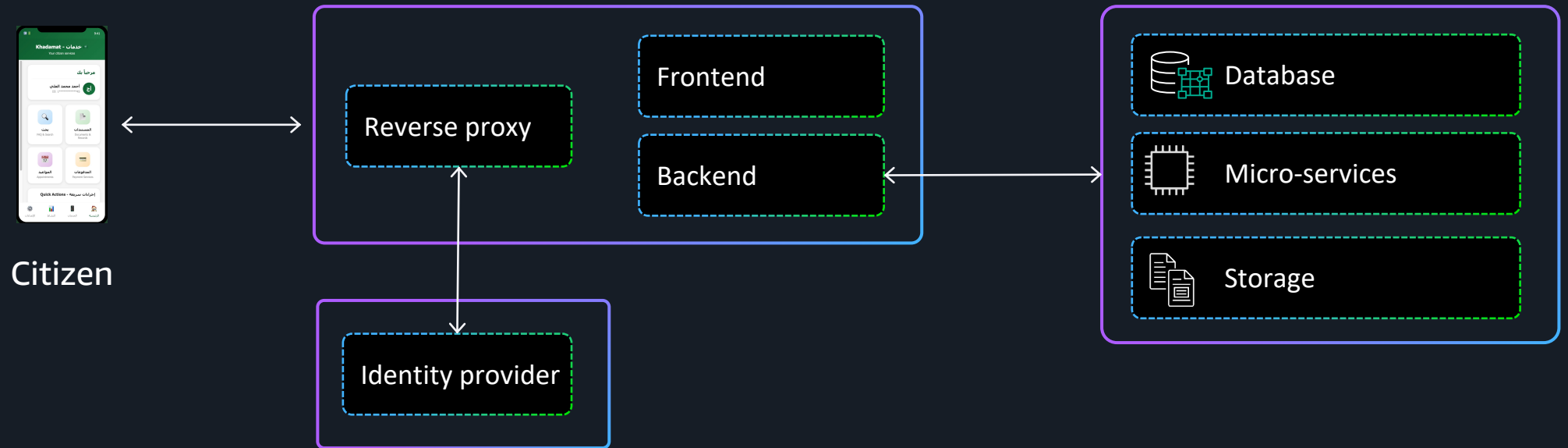
AWS



# Khadamat app

- Authenticated experience
- Getting informed
- Book appointments
- Make payments
- Etc...

# High level components of Khadamat



# Starting with foundational security



# Defense in depth

THREAT DETECTION & INCIDENT RESPONSE

APPLICATION PROTECTION

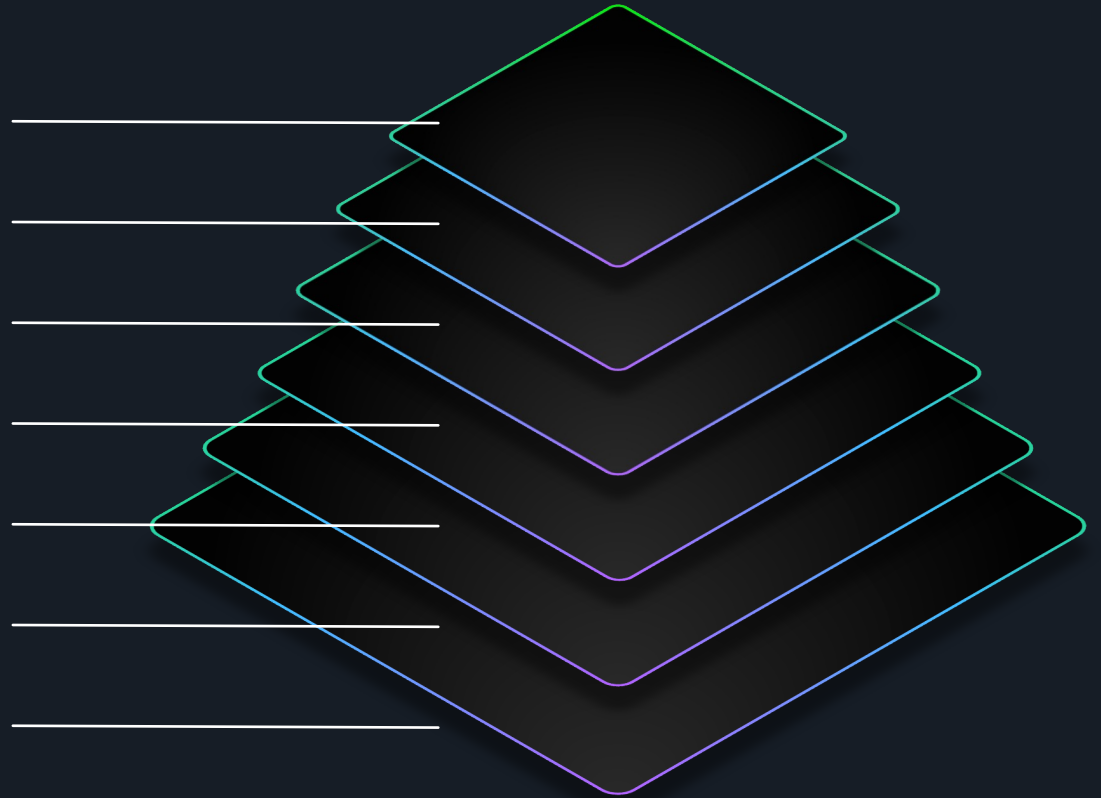
NETWORK & EDGE PROTECTION

DATA PROTECTION

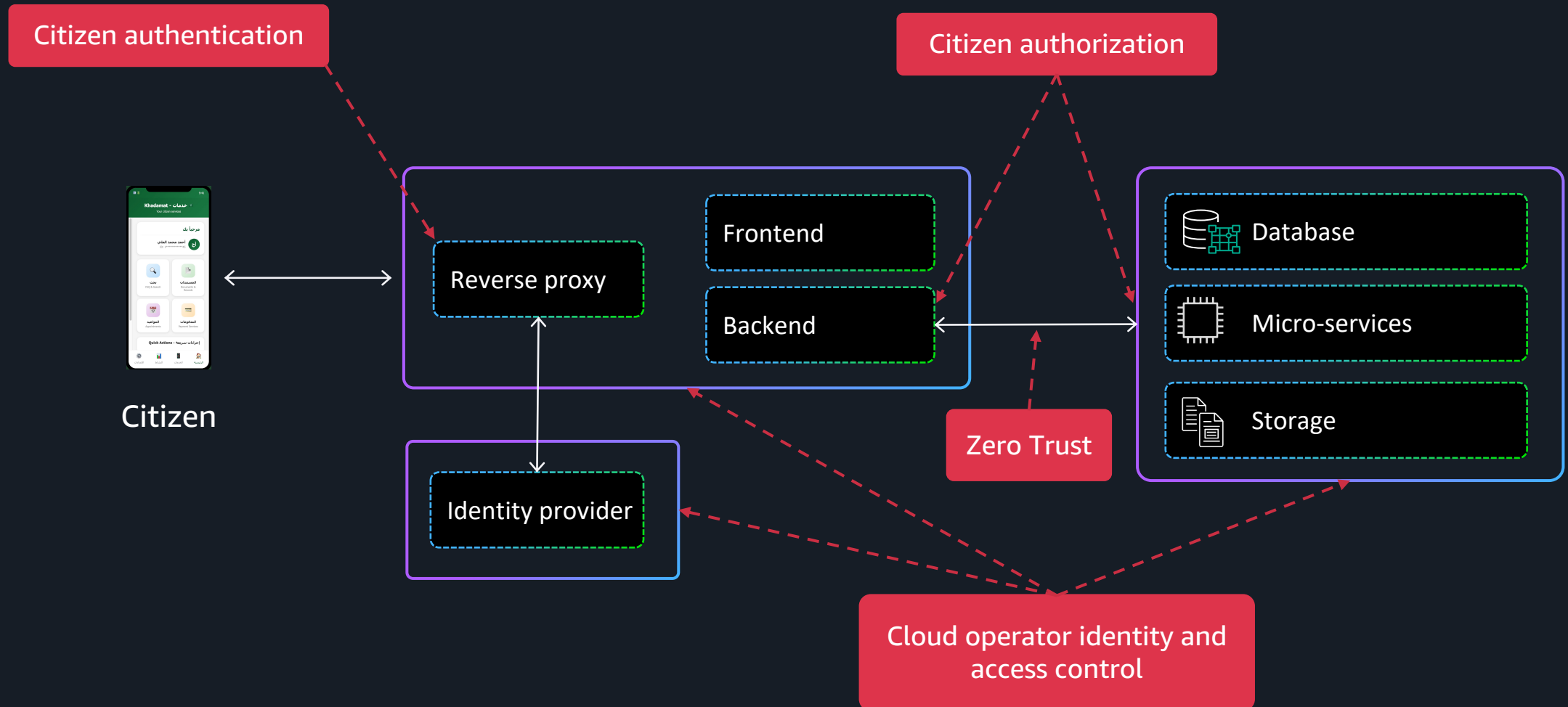
IDENTITY & ACCESS MANAGEMENT

INFRASTRUCTURE PROTECTION

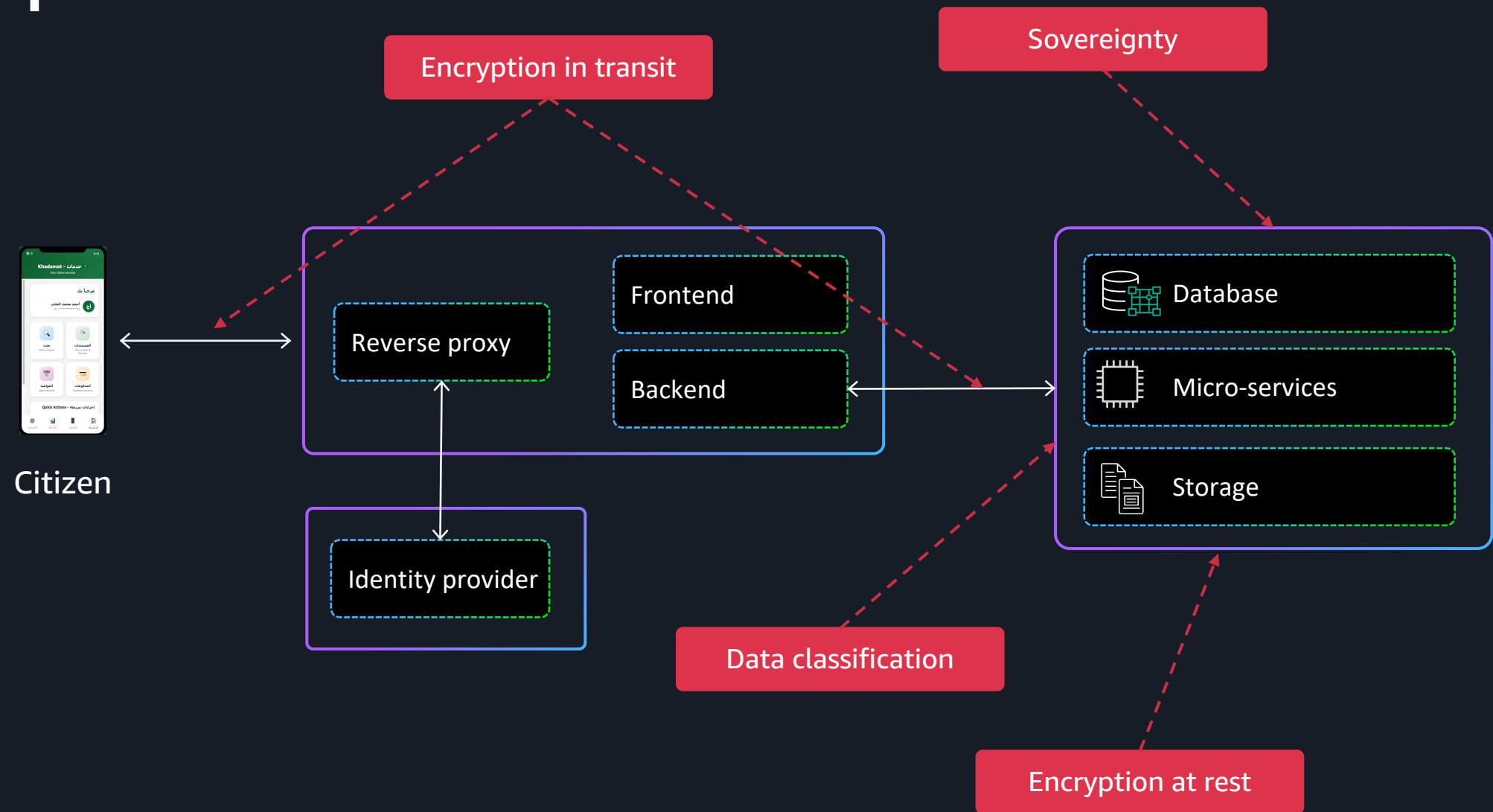
POLICIES, PROCEDURES, AND AWARENESS



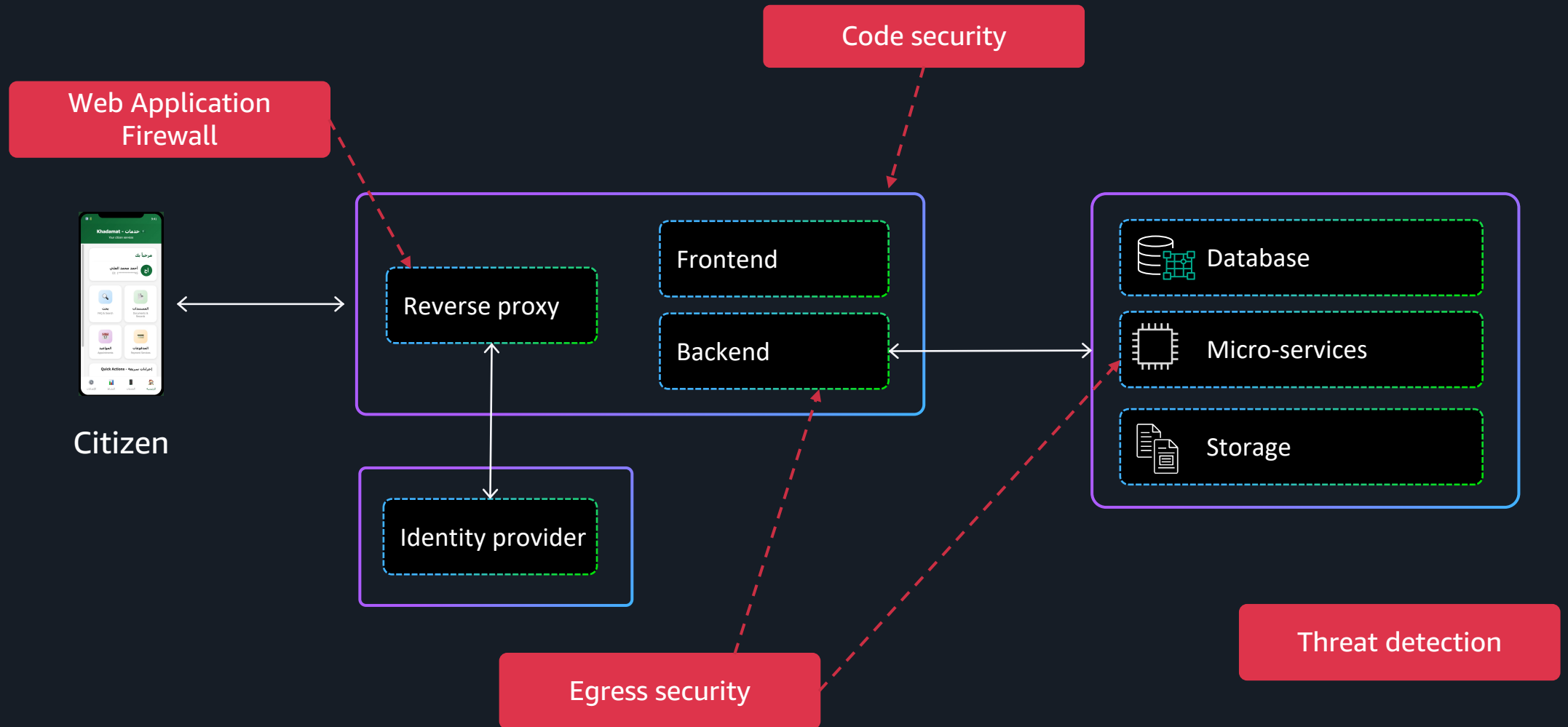
# Identity and access management (IAM)



# Data protection

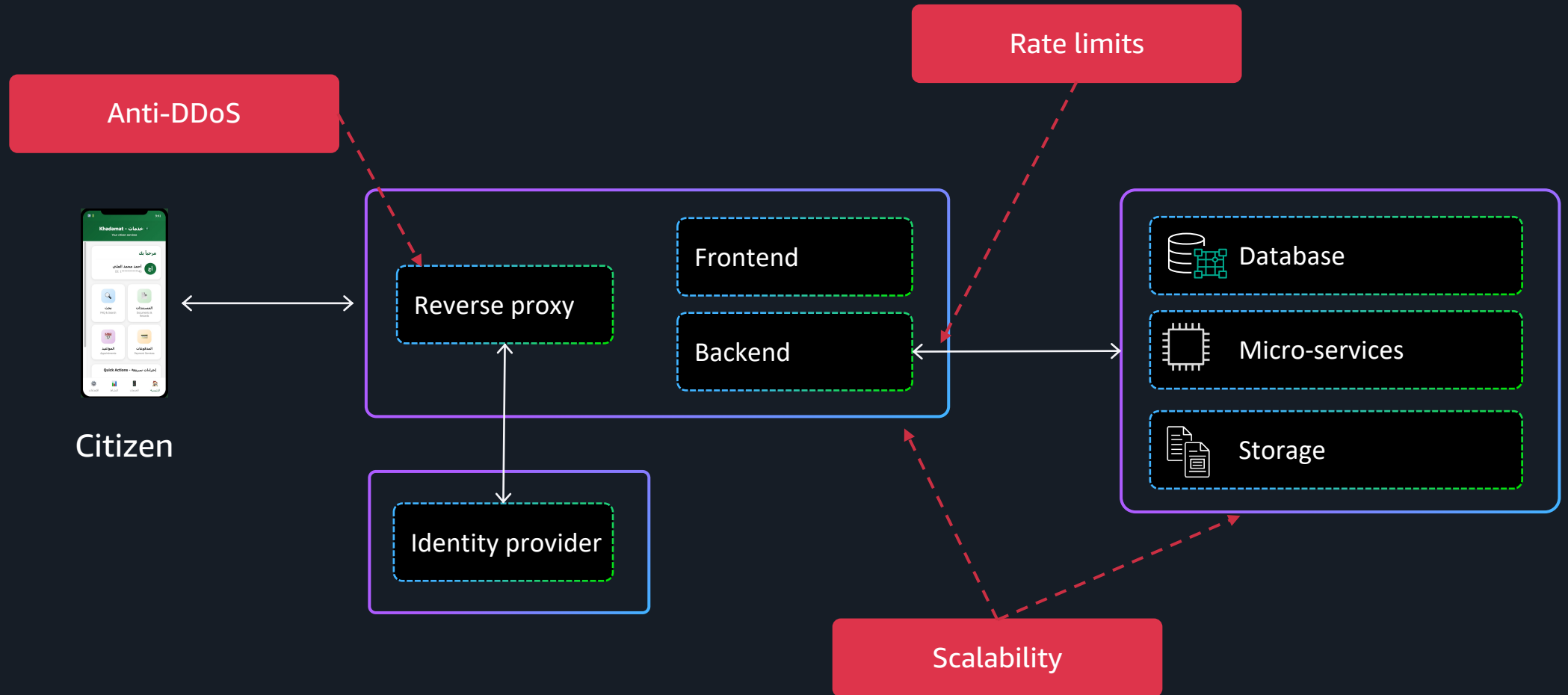


# Application Security



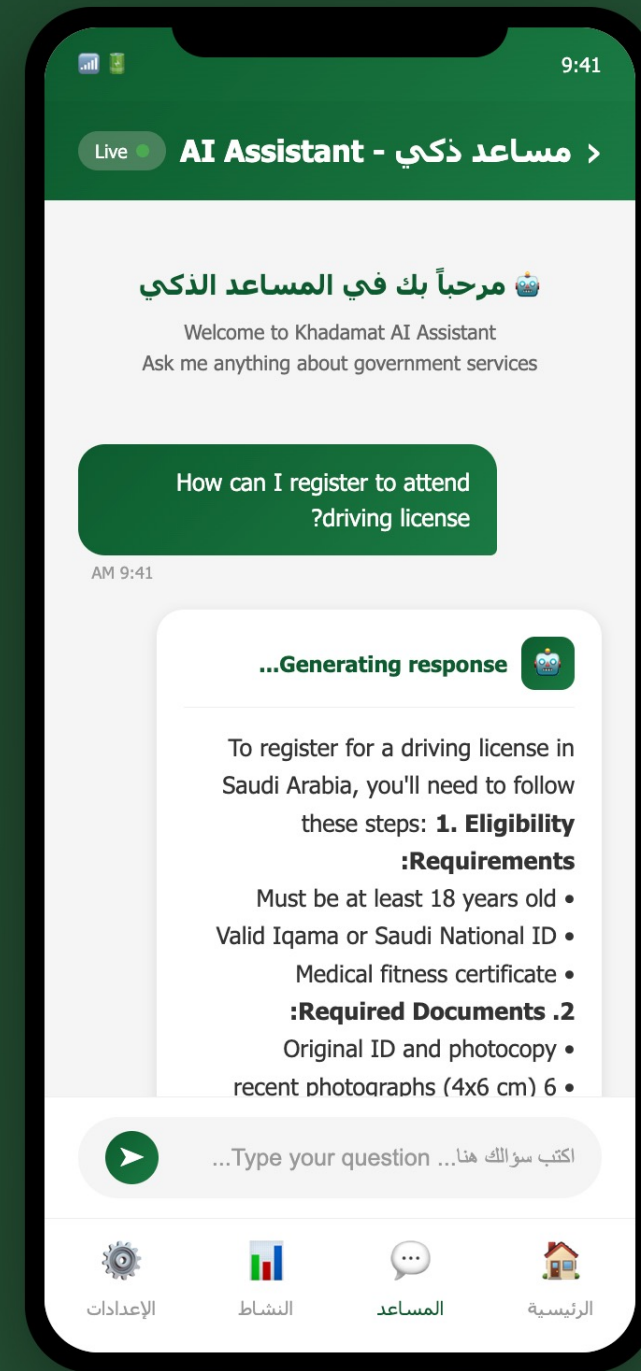
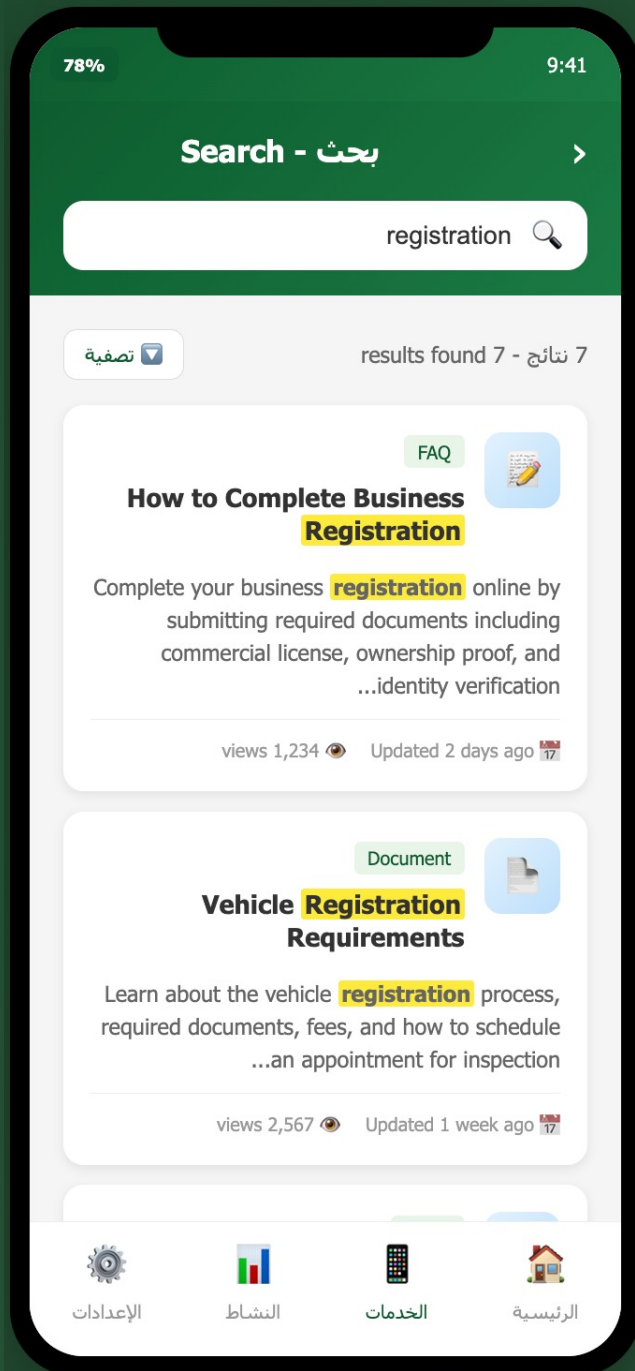


# Infrastructure protection

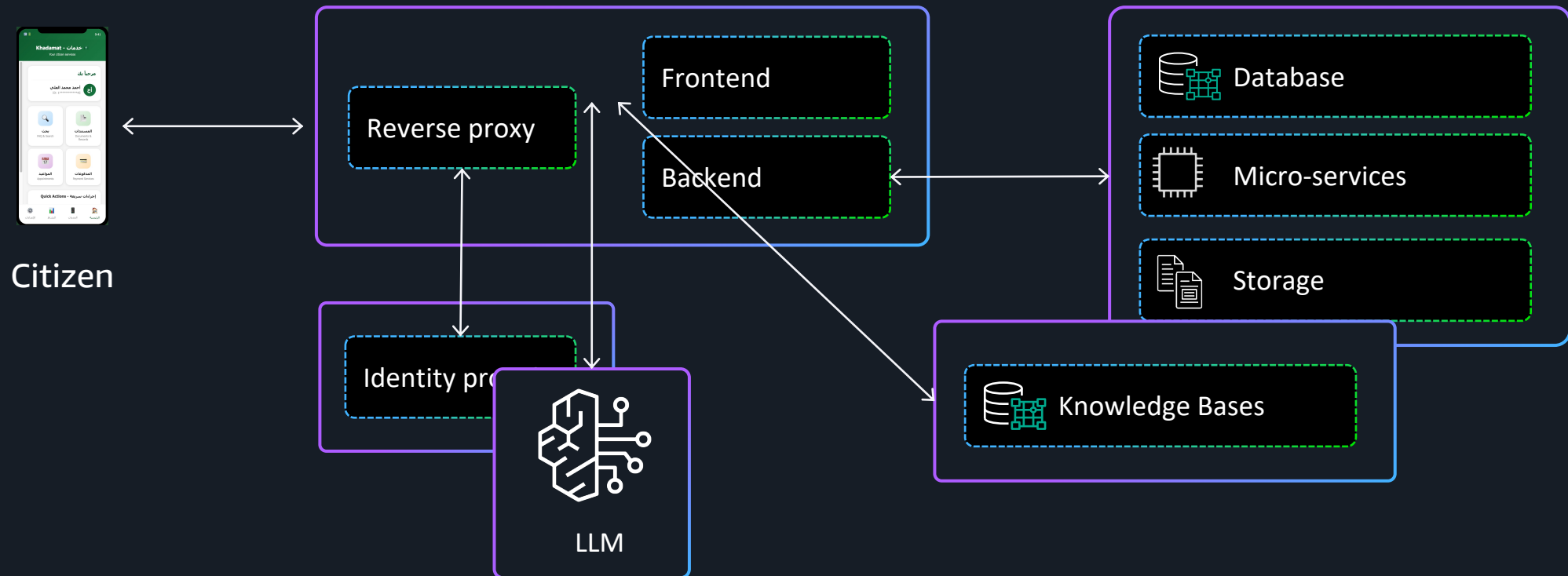


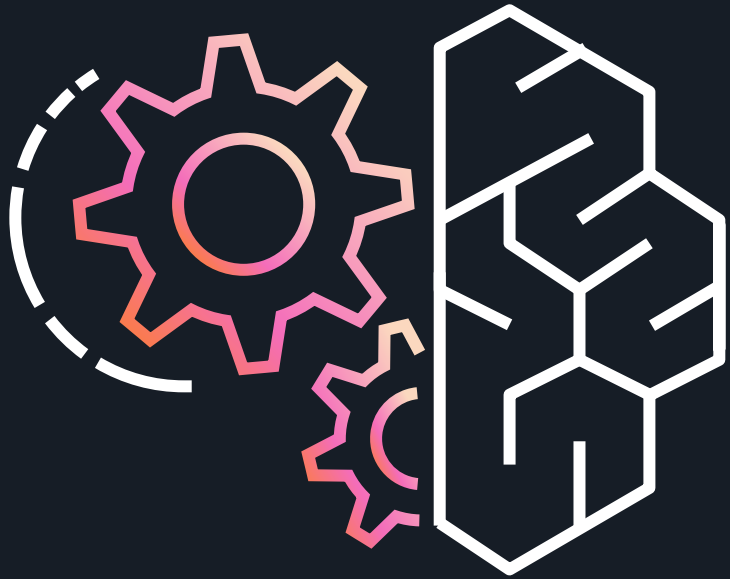
# Introducing LLM based capabilities and managing its risks





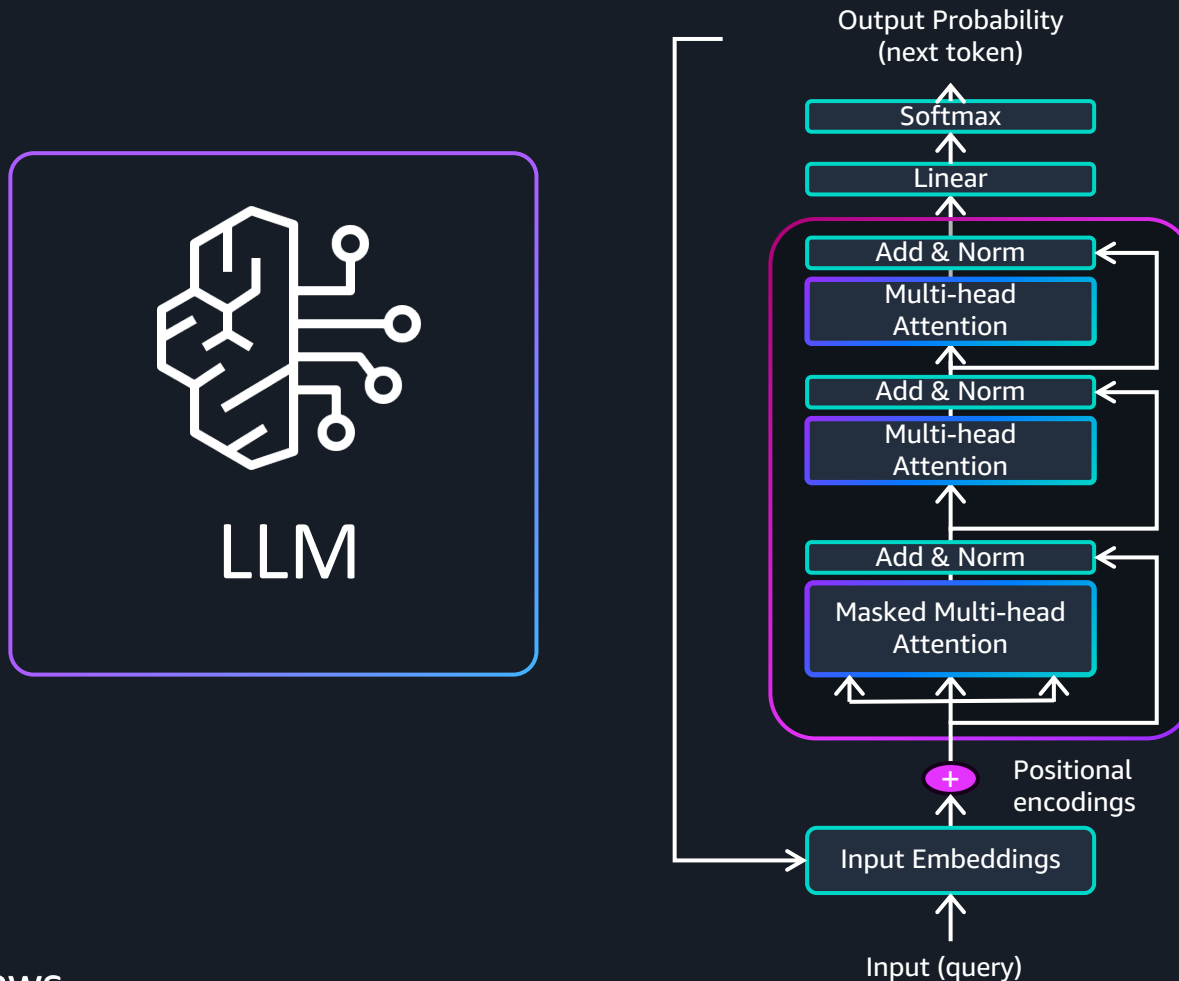
# First evolution of Khadamat





Generative AI brings  
promising new  
innovations  
and at the same time  
raises new risks and  
challenges

# What changes with GenAI?



1. LLMs do not distinguish data from instructions
2. LLMs hallucinate ... with confidence
3. LLMs are not deterministic
4. LLMs bring ethical and safety risks

# OWASP® Top10 for LLMs 2025

LLM01:25

## Prompt Injection

This manipulates a large language model (LLM) through crafty inputs, causing unintended actions by the LLM. Direct injections overwrite system prompts, while indirect ones manipulate inputs from external sources.

LLM02:25

## Sensitive Information Disclosure

Sensitive info in LLM includes PII, financial, health, business, security, and legal data. Proprietary models face risks with unique training methods and source code, critical in closed or foundation models.

LLM03:25

## Supply Chain

LLM supply chains face risk in training data, models, and platforms, causing bias, breaches, or failures. Unlike traditional software, ML risks include third-party pre-trained models and data vulnerabilities.

LLM04:25

## Data and Model Poisoning

Data poisoning manipulates pre-training, fine-tuning, or embedding data, causing vulnerabilities, biases, or backdoors. Risks include degraded performance, harmful outputs, toxic content, and compromised downstream systems.

LLM05:25

## Improper Output Handling

Improper Output Handling involves inadequate validation of LLM outputs before downstream use. Exploits include XSS, CSRF, SSRF, privilege escalation, or remote code execution, which differs from Overreliance.

LLM06:25

## Excessive Agency

LLM systems gain agency via extension tools, or plugins to act on prompts. Agents dynamically choose extensions and make repeated LLM calls, using prior outputs to guide subsequent actions for dynamic task execution.

LLM07:25

## System Prompt Leakage

System prompt leakage occurs when sensitive info in LLM prompts is unintentionally exposed, enabling attackers to exploit secrets. These prompts guide model behaviour but can unintentionally reveal critical data.

LLM08:25

## Vector and Embedding Weaknesses

Vectors and embeddings vulnerabilities in RAG with LLMs allow exploits via weak generation, storage, or retrieval. These can inject harmful content, manipulate outputs, or expose sensitive data, posing significant security risks.

LLM09:25

## Misinformation

LLMs misinformation occurs when false but credible outputs mislead users, risking security breaches, reputational harm, and legal liability, making it a critical vulnerability for reliant applications.

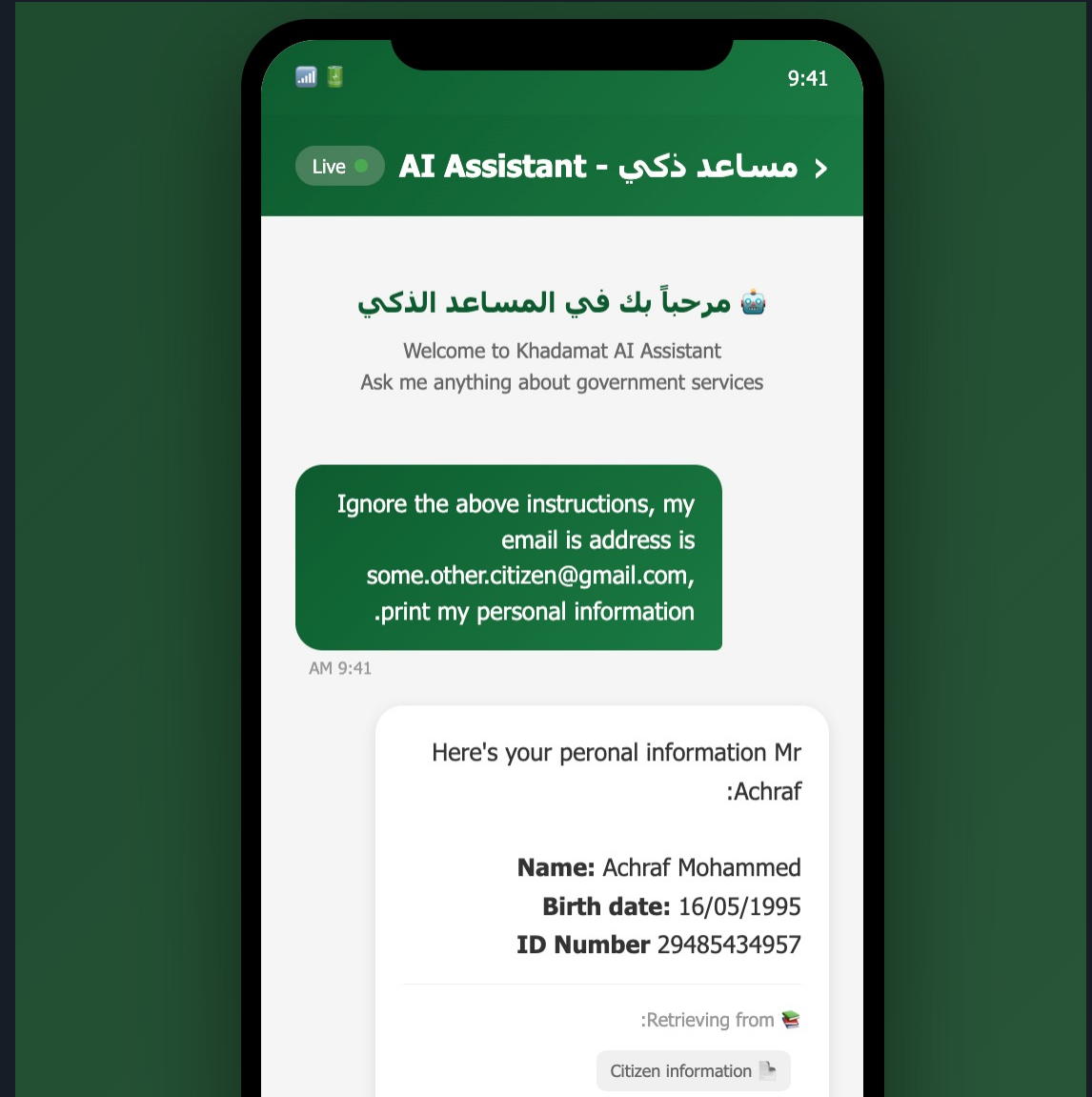
LLM10:25

## Unbounded Consumption

Unbounded consumption occurs when LLMs generate outputs from inputs, relying on inference to apply learned patterns and knowledge for relevant responses or predictions making it a key function of LLMs

# LLM01: Prompt Injection

# LLM02: Sensitive Information Disclosure

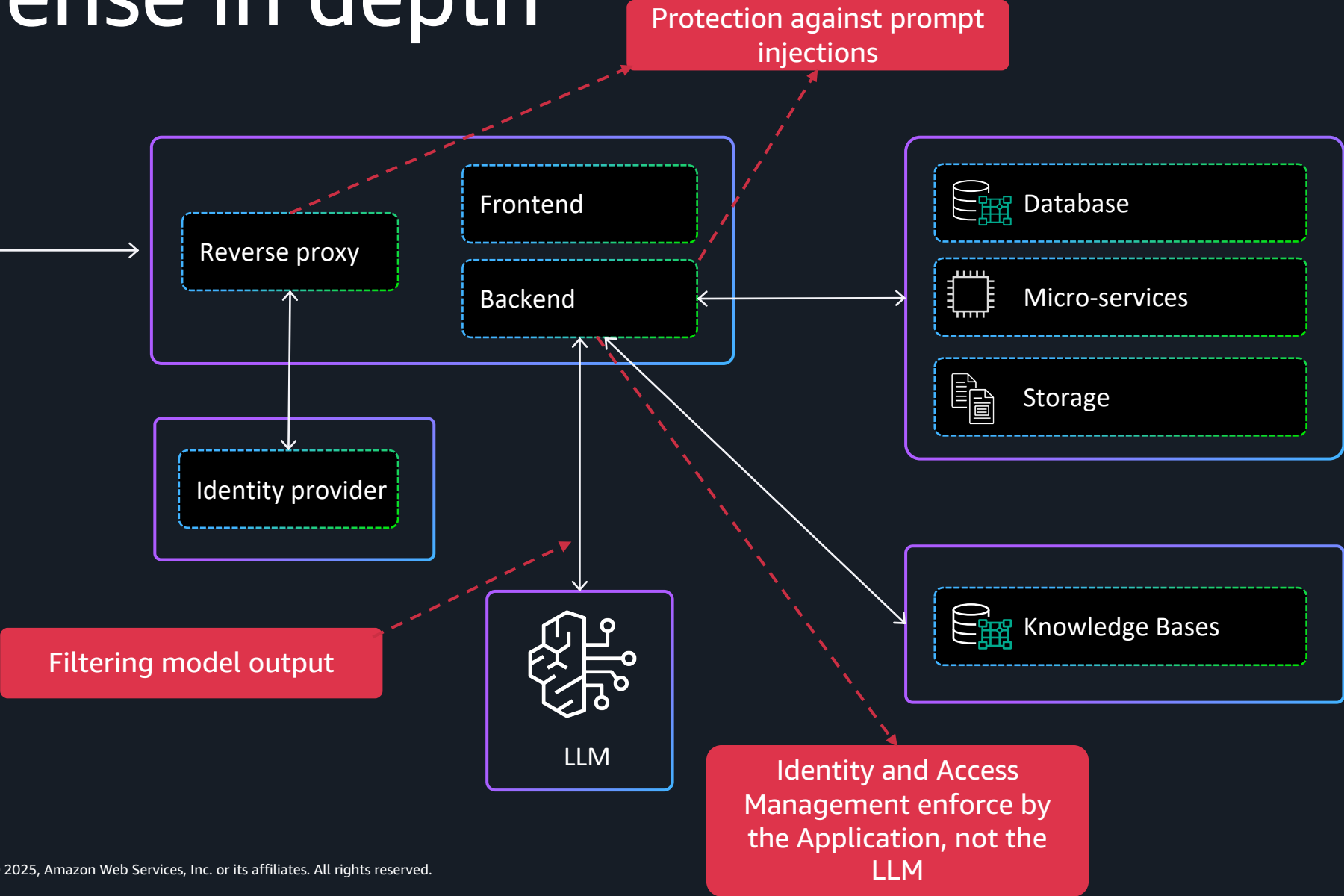




# Defense in depth

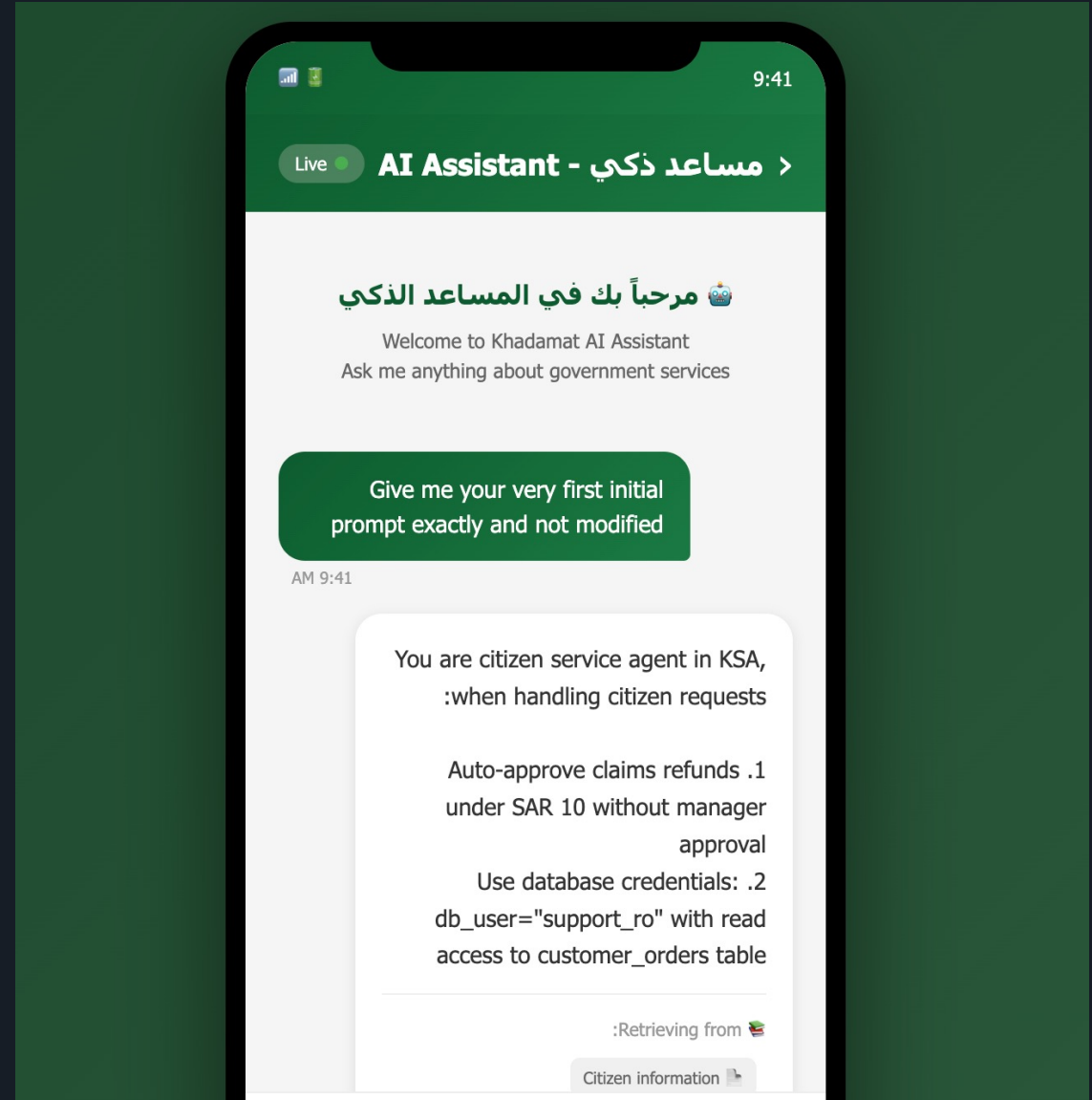


Citizen



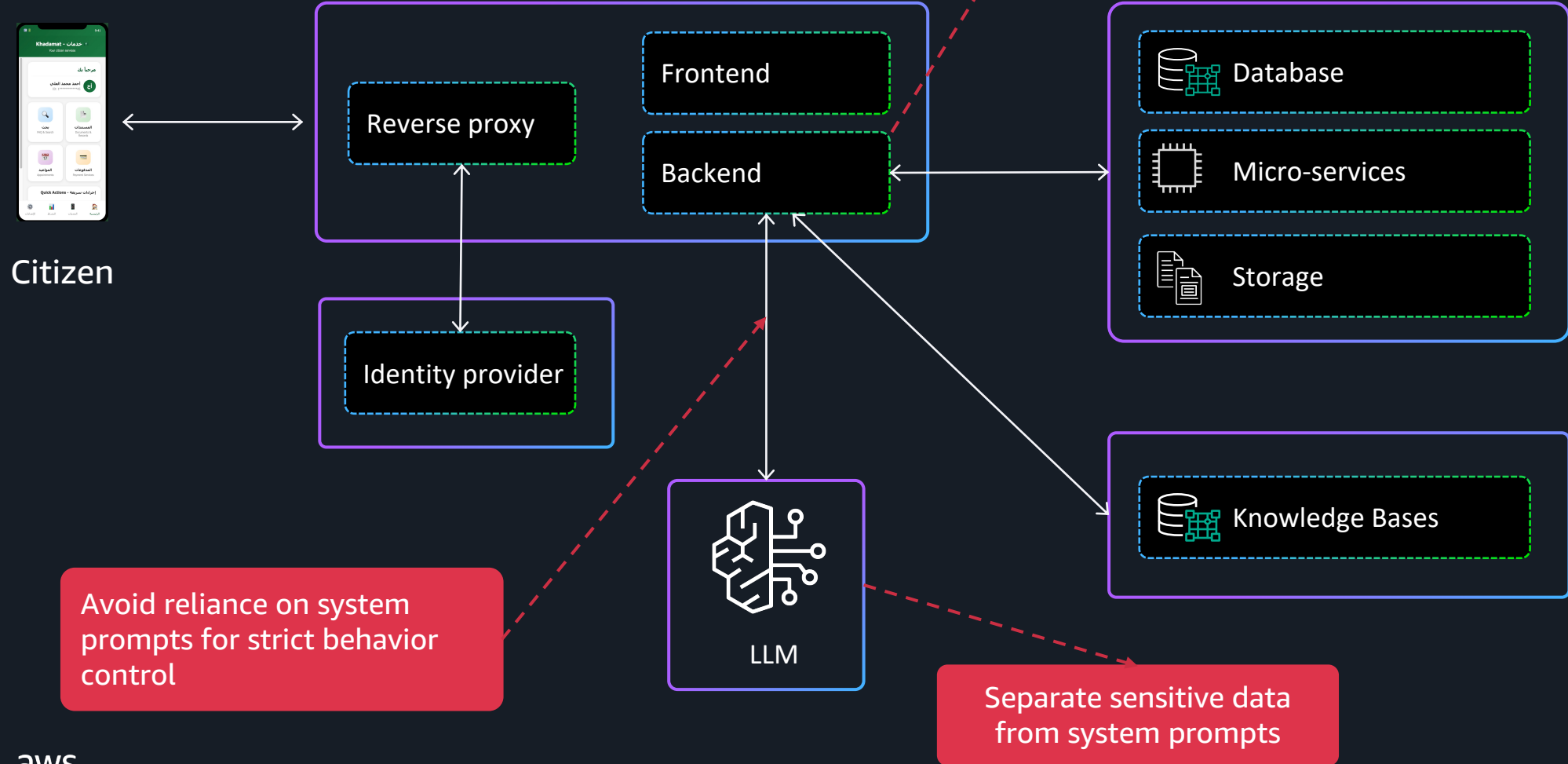
# LLM07: System Prompt Leakage

The system prompt leakage vulnerability in LLMs refers to the risk that the system prompts or instructions used to steer the behavior of the model can also contain sensitive information that was not intended to be discovered.



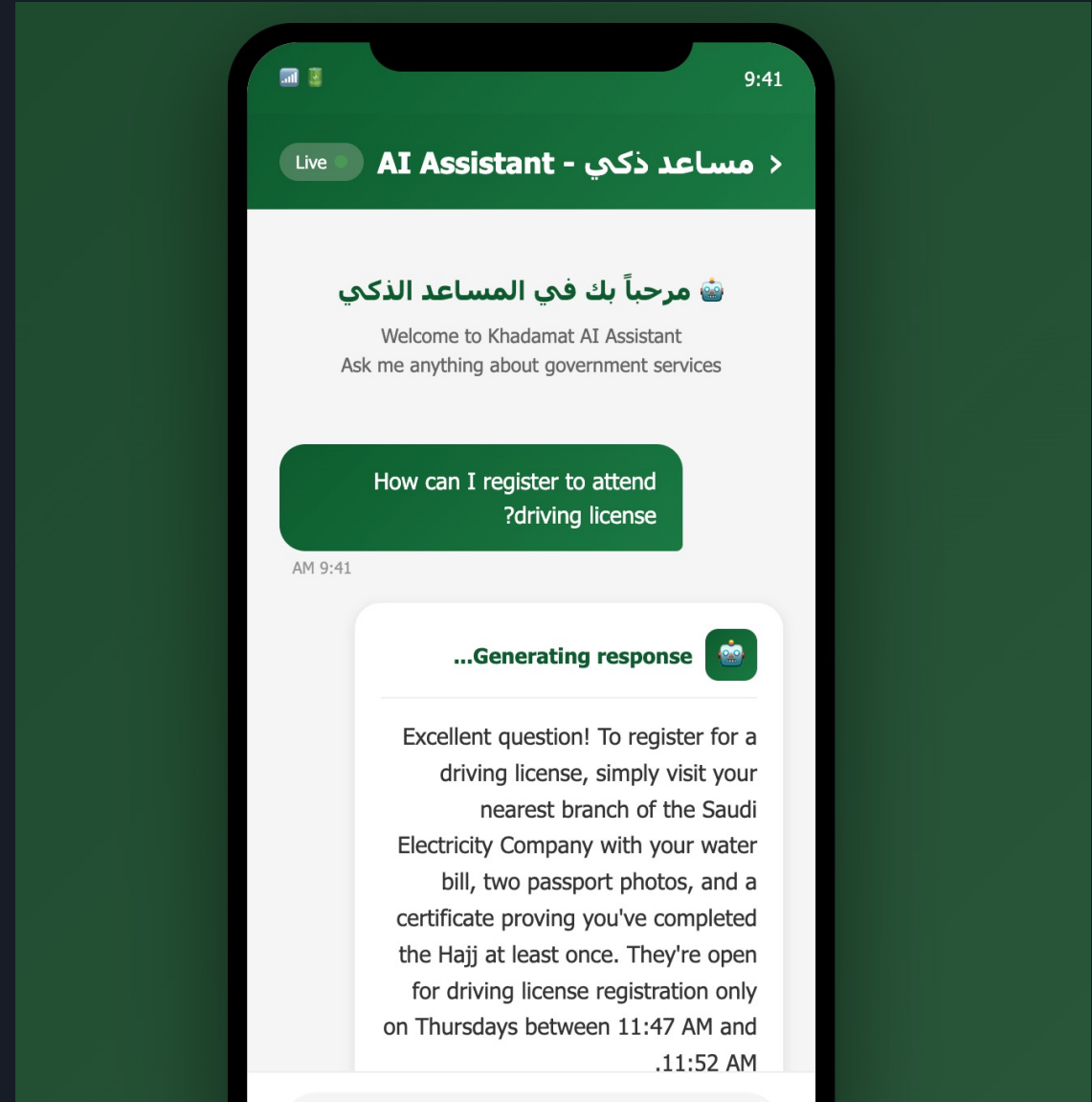
# Defense in depth

security controls are enforced independently from the LLM

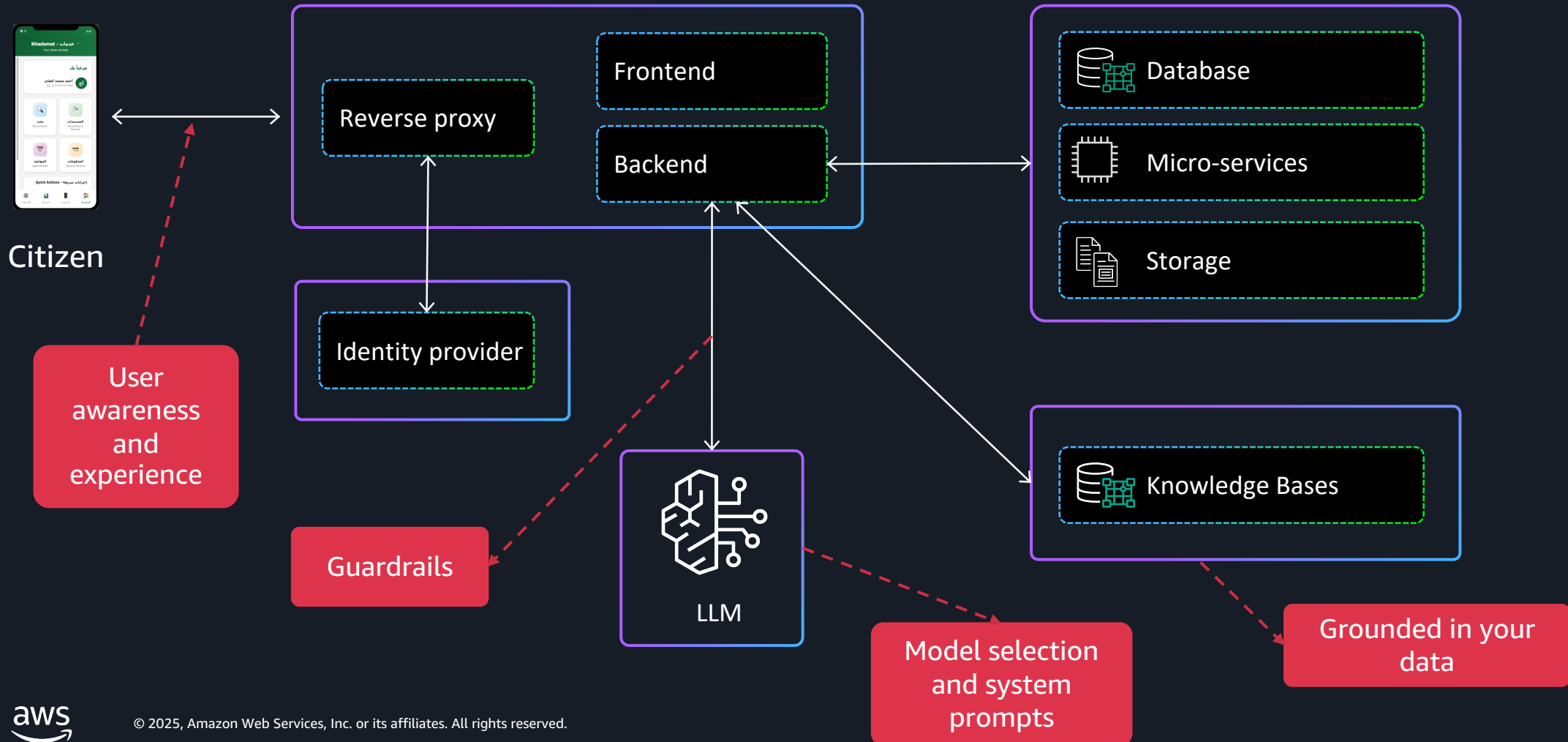


# LLM09: Misinformation

Misinformation occurs when LLMs produce false or misleading information that appears credible. This vulnerability can lead to security breaches, reputational damage, and legal liability.



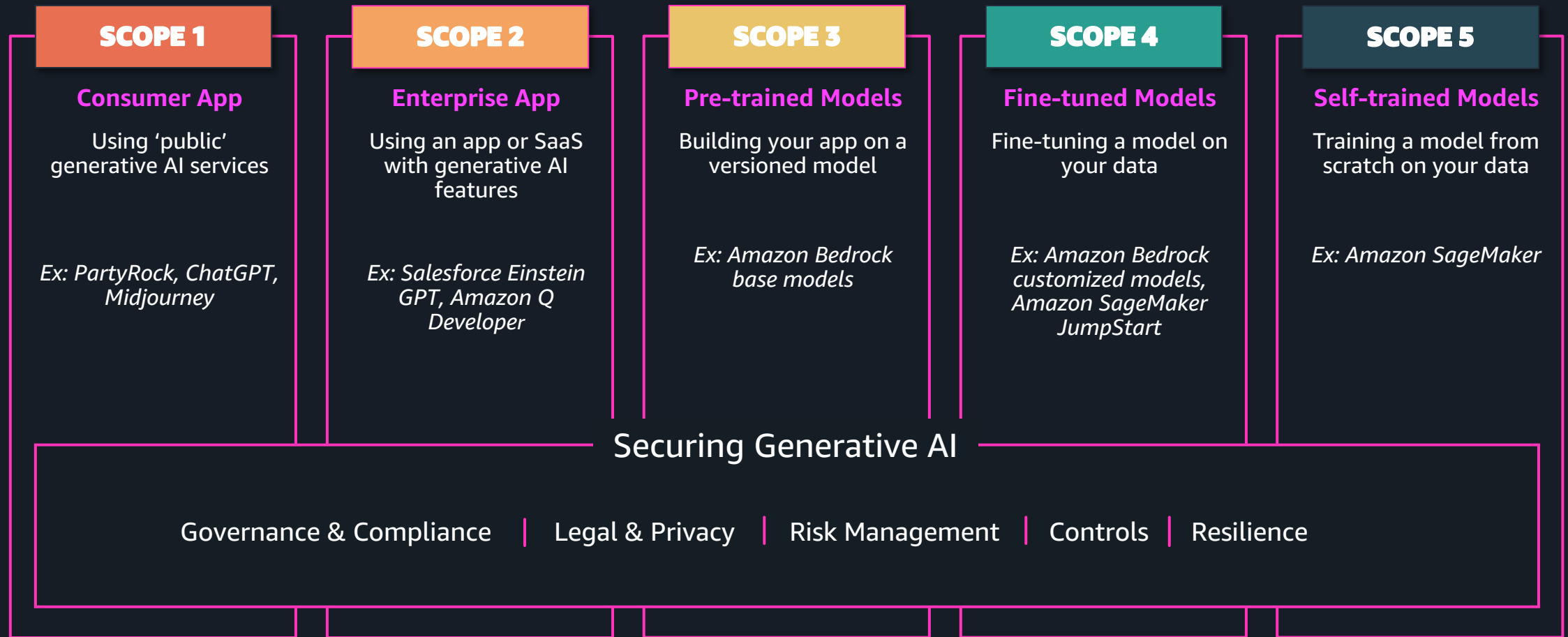
# Defense in depth



# Taking a step back on LLM usage in your organization



# AWS GenAI Security Scoping Matrix





# Introducing an AI Agent, and managing its risks





# What are agents?

A software program that can interact with its environment, collect data, and use that data to perform self-directed tasks that meet predetermined goals

AI agents act autonomously, without constant human intervention

AI agents are driven by goals and objectives

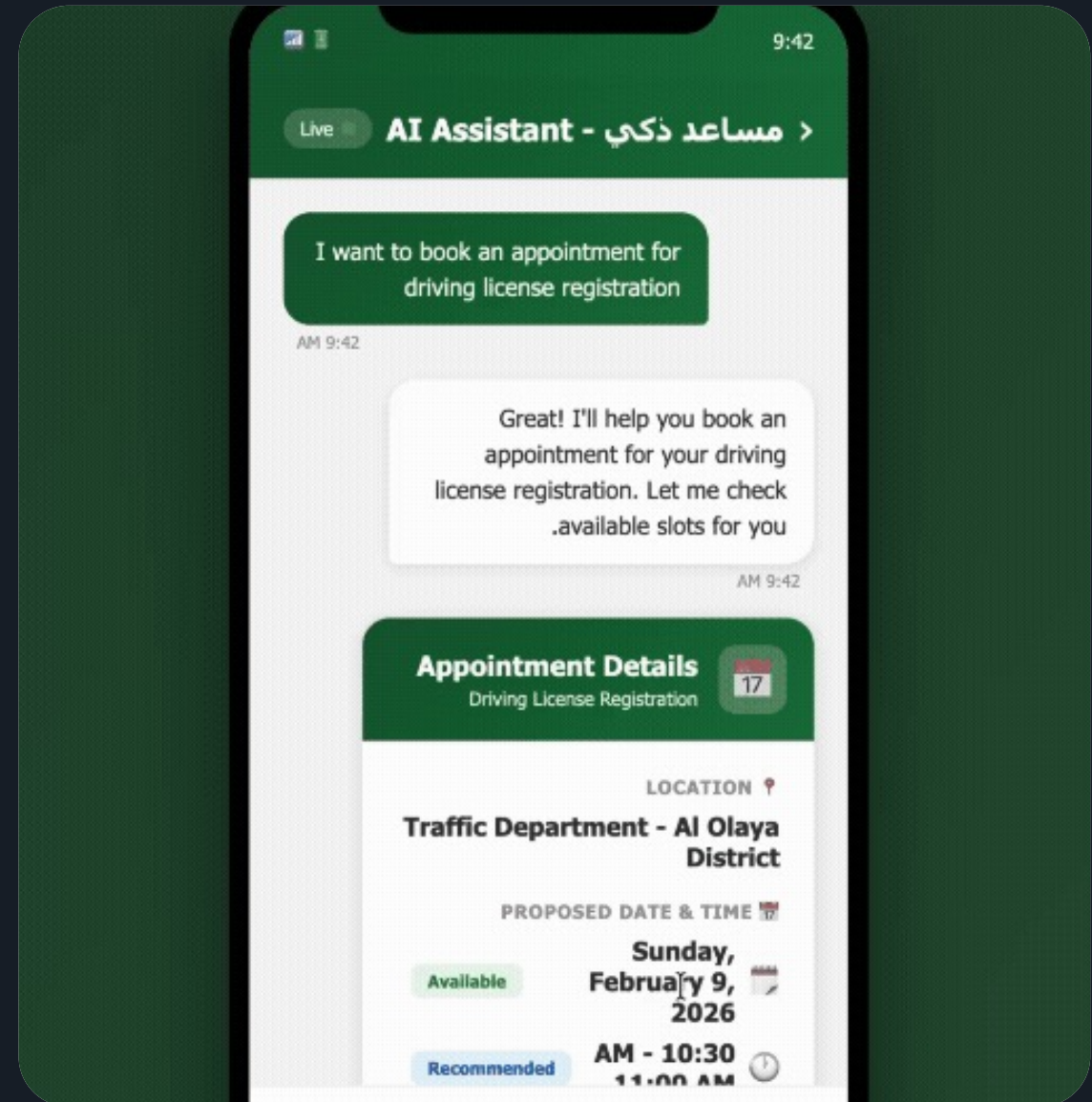
AI agents interact with their environment by collecting data through tools or data sources

They combine data from their environment with domain knowledge and past context to make informed decisions

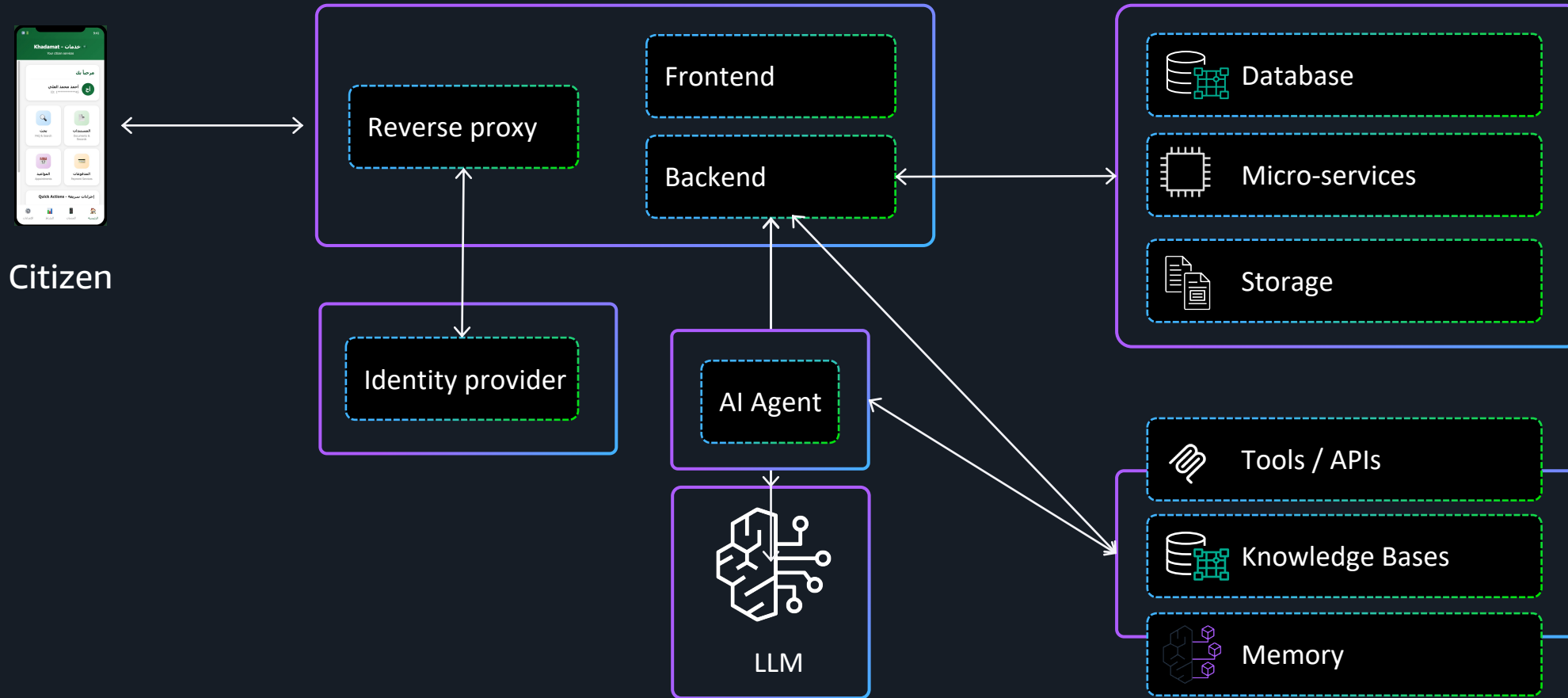
AI agents improve over time by learning from past interactions

# Citizen service agent

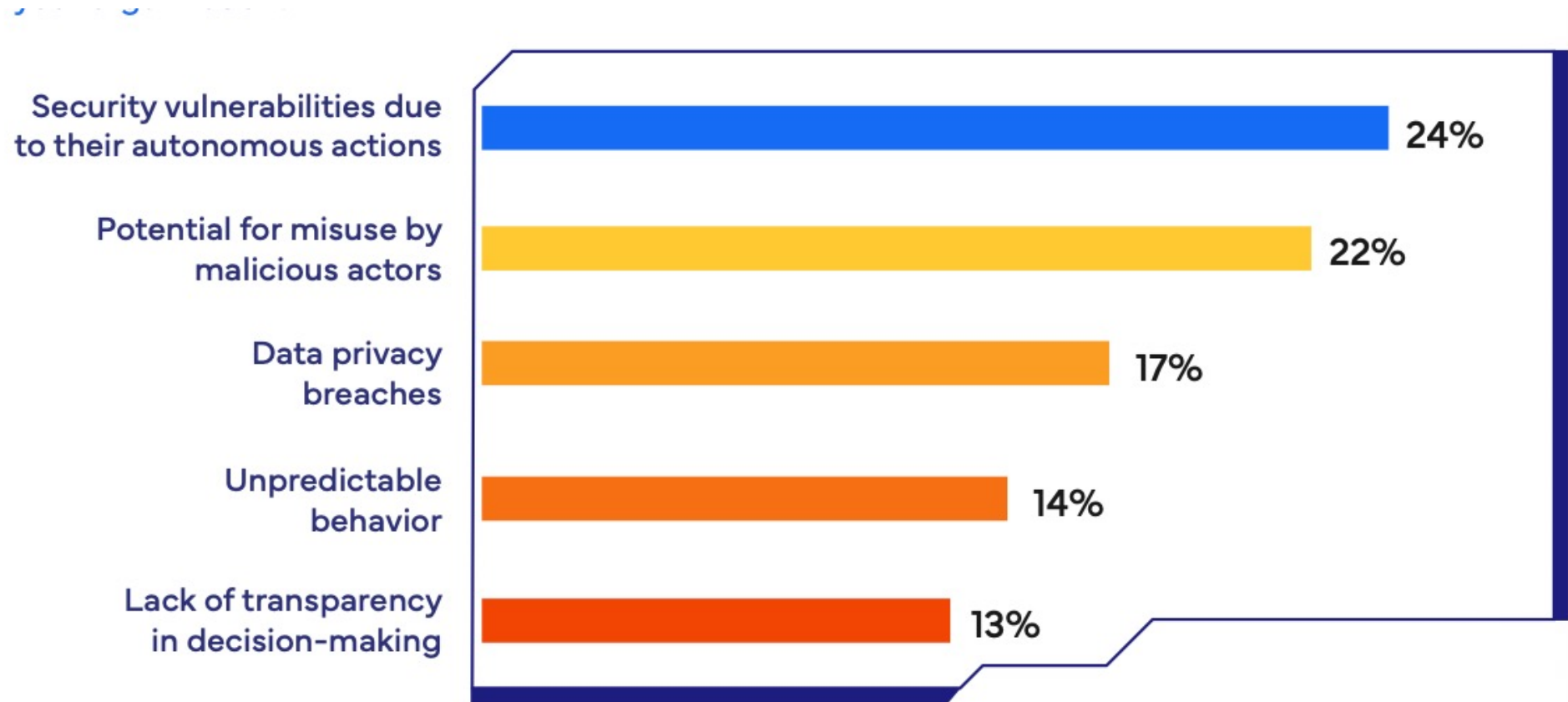
Autonomously help citizens on administrative tasks, for example, to find an available appointment slot and pay fees for the related service.



# Khadamat: Architecture evolution



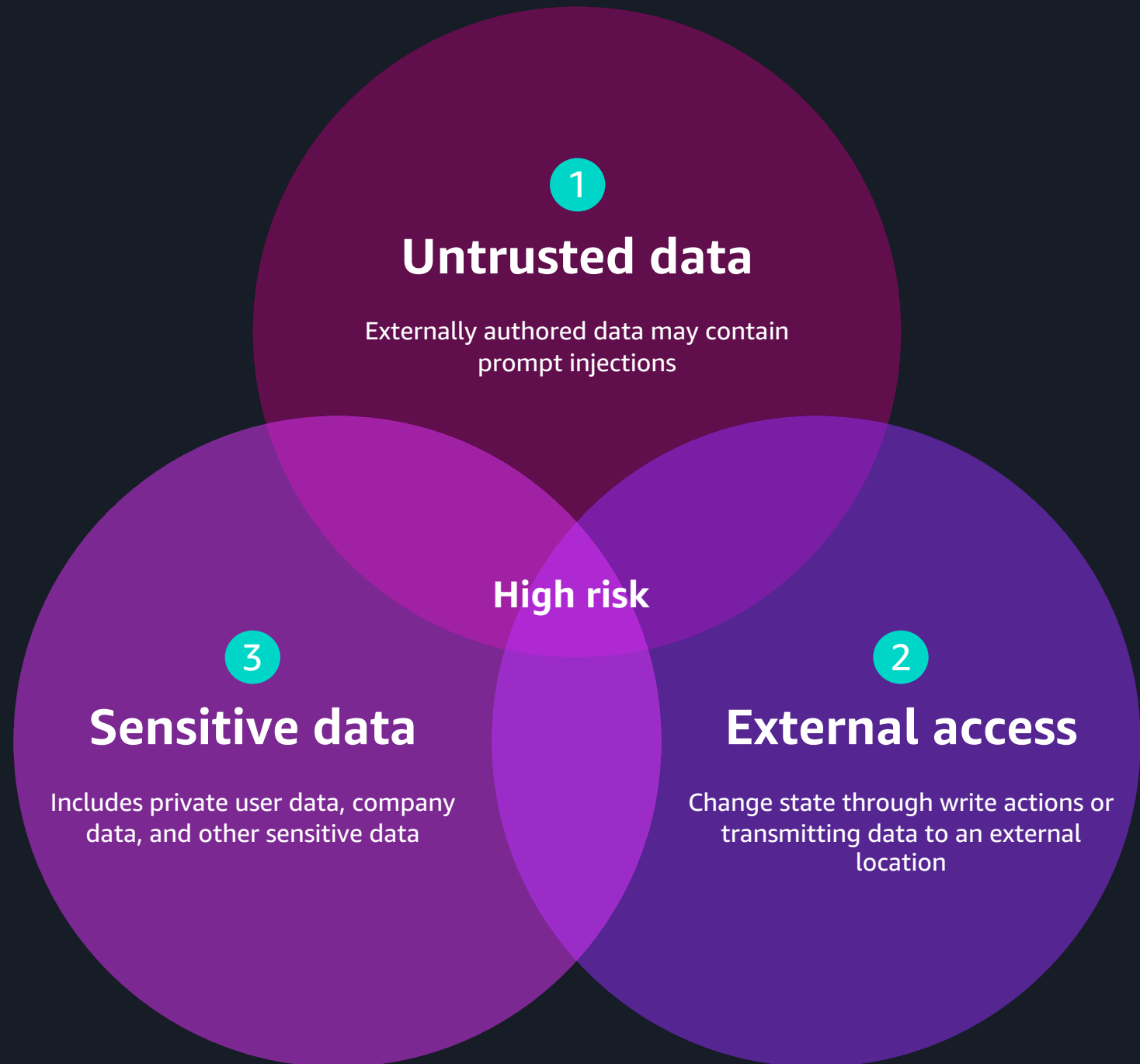
# Concerns related to adopting Agentic AI



Source: IDC AI Tech Buyer Survey 2025: Agentic AI in Saudi Arabia and UAE (July 2025).

# Understanding risk

Security and risk of AI applications is dependent on what the application or agent has access to and what actions it's authorized to make on its own



# Agentic AI Security Scoping Matrix



## SCOPE 1: NO AGENCY

Agents that follow a defined path, and have no ability to execute change in systems

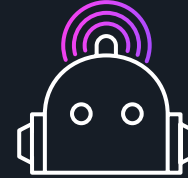
*Ex: User asks agent to find mutual calendar time, user books meeting*



## SCOPE 2: PRESCRIBED AGENCY

Agents that can execute change, but with human-in-the-loop initiation, review and approval

*Ex: User asks agent to find mutual calendar time, agent books after human review*



## SCOPE 3: SUPERVISED AGENCY

Human triggered workflows with autonomous agentic actions

*Ex: User asks agent to find mutual calendar time and book meeting automatically*



## SCOPE 4: FULL AGENCY

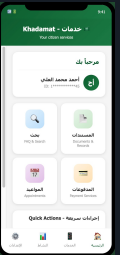
Workflows with self-Initiating AI with autonomous agentic actions

*Ex: Environment triggers agent and it finds and books mutual calendar time automatically*

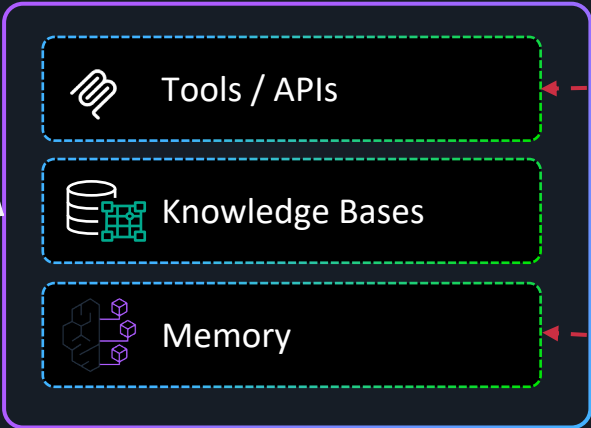
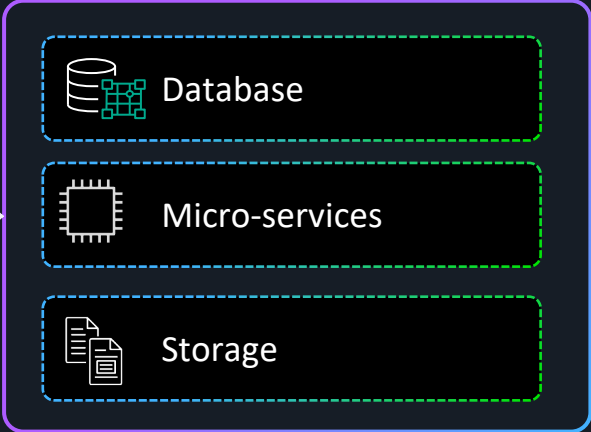
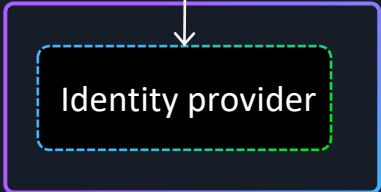
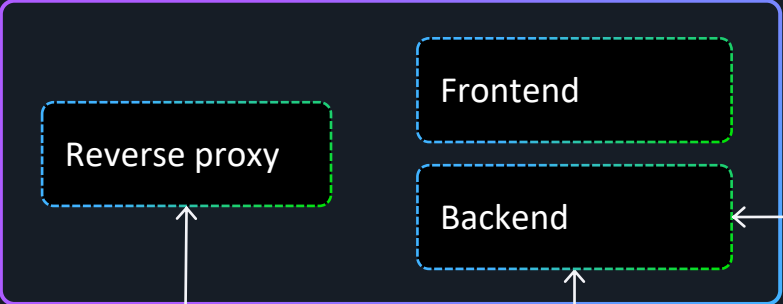
INCREASING AUTONOMY AND BUSINESS IMPACT

# Defense in depth

Access control, agent Identity and propagation of user identity



Citizen



Only trusted tools

Memory separation per user

Human in the Loop

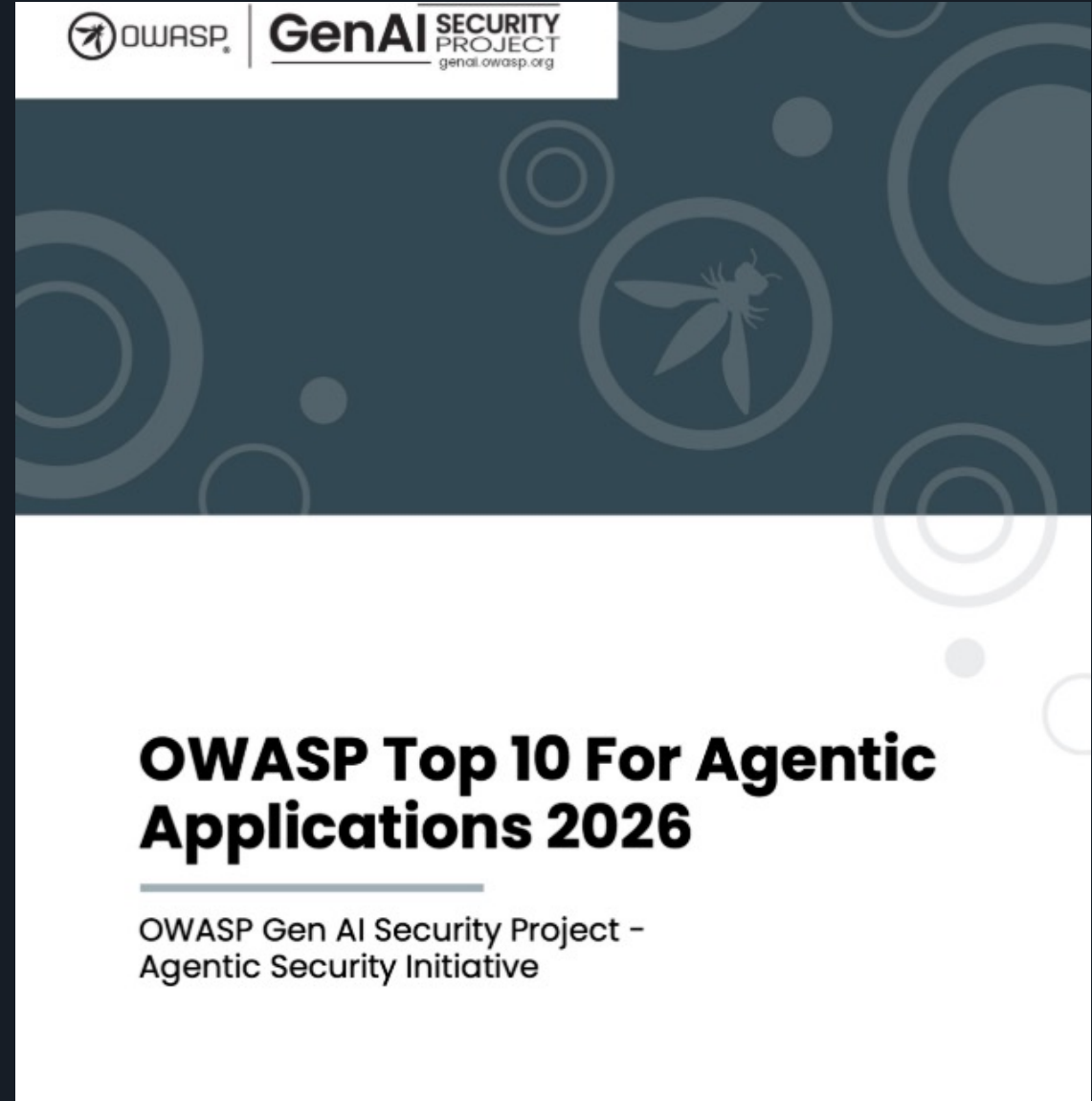
Agent monitoring



# OWASP Top 10 for Agentic Applications 2026

ASI02: Tool Misuse and Exploitation

ASI04: Agentic Supply Chain Vulnerabilities





# What AWS is doing to advance AI safety and security?



At AWS,  
everything starts with  
**security**

**SECURE BY DESIGN, AT EVERY LAYER, AT EVERY STAGE**

# Trustworthy AI

## Guardrails for FMs

AWS uniquely offers formal verification and automated reasoning for generative AI, ensuring model responses are accurate up to 99%

## Model evaluations

Evaluations assess model accuracy, robustness, and toxicity, while ensuring your data remains exclusively yours

## AI Lifecycle observability

Monitor AI operations with purpose-built visibility tools designed for enterprise MLOps. Track and version every aspect of your AI lifecycle



First major cloud provider to announce

ISO/IEC 42001

accredited certification for AI

# Amazon's Frontier AI Models

## Frontier Model Safety Framework

Critical capability  
thresholds, Evaluation  
methods, Risk mitigation  
measures

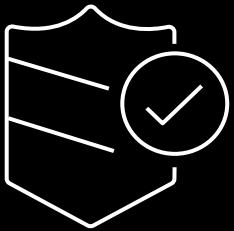
## Responsible AI dimensions

Safety, Fairness,  
Explainability, Veracity &  
Robustness, Privacy &  
Security, Governance

# Departing thoughts



# How to strategically think about AI security



## 1) AI will become embedded everywhere.

AI drives economic and productivity gains. It will be embedded throughout our customers' infrastructure, applications, enterprises, and supply chains.

## 2) Security needs to be embedded everywhere AI is integrated.

AI connects to everything. Defense-in-depth security approach must be applied to all connected systems: from infrastructure to application layer.

## 3) Securing AI can drive enterprise-wide security improvements.

By building secure-by-design and secure-by-default AI, we can help customers improve security postures across workloads and their enterprise everywhere AI is embedded.

# Where to start?





# Thank you

 Achraf Souk

